

Breakdown Of Marriott International's Cyber Attack

Whether they are small or large, every business assumes some risk of being targeted by a cyber-attack. The assumption being a larger company would be able to prevent an attack or mitigate the fallout within a smaller timeframe due to constant surveillance. Unfortunately, this was not the case with Marriott International's cyber-attack perpetrated during 2014-2018. The crux of this cyber attack can be summarized as a data breach of over half a billion logs and records of their clients, including USA military and government officials. The data includes "hundreds of millions of customer records (Fruhlinger, 2020) " which contained not only names and phone numbers but credit card information as well as passport, driver's licenses, and other identification cards. There are many aspects to this breach, including the main adversary, which was later found to be the Chinese intelligence agency. The reason for the Marriot becoming a victim was very incidental. The target was chosen because many Americans use this hotel chain when visiting other countries, including the USA military and political figures. Using the diamond model, a pronounced method and reason will be derived to understand why this event occurred.

The main adversary of Marriot international was Chinese intelligence officers who were trying to gain information about the United States of America Citizens. This attack is different from a typical cyber-attack because the stolen content has not been sold to outside sources, which later corroborates that the source behind the attacks was a nation. The problem Marriot international faced began when they acquired Starwood Hotels and Resorts

Worldwide, Inc. in 2015, which made them "the world's largest hotel operator. (Hertzfeld, 2018)". While being a bigger chain would have already made them a bigger target, the main problem they had stems from the fact hacking groups had already been "inside Starwood's computer networks since 2014 (Hertzfeld, 2018)", so when they combined their systems, they let a fox into the hen house.

The capabilities of the hacking groups later were used to identify the adversary. Specific tools and methods used almost exclusively by Chinese run actors were found on Starwood computers. The attack's two key components were a " Remote Access Trojan (RAT) along with MimiKatz (Fruhlinger, 2020) ". The trojan was used to gain remote administrative privileges necessary for mimikatz, an open-source hacking tool. Mimikatz is primarily used for windows machines to "to view and save authentication credentials (Petters, 2020)". It is essentially a sniffer that can collect and then later send out save information back to the adversary through its existing infrastructure.

The infrastructure used to deliver the initial trojan horse was believed to be a phishing email communicated to various hosts. When dealing with nation-states, its hosts or infrastructure locations don't necessarily implicate or absolve a nation because they can easily afford to have their attacks set up in different countries.

The Victim was Marriot international, and all of their customers who's flight information and credit card information were stolen. In understanding the value, Marriot customers bring, it is easier to understand why Marriot was targeted. The ability to know the movements of influential business leaders or government officials could be an early signal of something significant about to happen. For instance, if the United States president suddenly went to Iraq and stayed at a Marriot, the Chinese government could assume a big deal might be

underway in that region. Typically when dealing with smaller hacking groups, that main objective would have been credit card information. Still, cyber experts can infer that this hack was not motivated financially because the information was never leaked.

Axiom 1 of the diamond model is looking for the adversary that is causing the intrusion. The adversary, in this case, is the Chinese intelligence agency used various open sources products such as MimiKatz to create a persistent presence in the Marriot international databases because of its new affiliation with Starwood., A merger between two companies of such scale means the combining and consolidation of many departments, which leads to a lot of internal confusion. A significant problem with Starwood was it collected a lot of "historical information about its customers, (WSJ Pro,2018)" which is never a great idea to continue to hold information that is not needed to operate. In an attempt to grow, Marriot let in a company with various security flaws and exploits, which later showed how essential a part of business cybersecurity is to company infrastructure and why it should not be forgotten. On paper, converting a physical location to another brand may be as easy as a simple remodel, but the programs and internal operations are entirely different. When nations such as China already have a vast cyber hacking infrastructure target American companies, their presence can be hidden and persistent.

Marriott, "the top hotel provider for United States government and military personnel. (Newstex ,2018)", can be used to determine a clear social-political relationship with its adversary china and fulfill axiom 2 of the diamond model to show adversaries' intent against Marriot. The United States of America and the Chinese government are in a cyber cold war to this day, with even companies such as Huawei leaving the united states based on suspicions that they were being used to infiltrate USA's citizens' private information. Axiom 6 of the diamond model

would characterize this relationship as close because these governments are highly interconnected through trade and policy. The Marriot falls into a victim of opportunity because it was initially targeted primarily because Chinese intelligence was already in Starwood. Once the data breach was located, more attempts were not made to regain install sniffer. The treat or adversary had an enduring degree of persistence because they could go unnoticed for over four years. This relationship shows other vital features that the attacker had, like enormous capital to maintain the operation without selling the stolen information. Credit card information usually expires within 4-5 years, with some exclusive cards expiring much quicker for security purposes. Knowing how long the sniffer was active and knowing no credit card information was sold from this event means that Victim satisfied a completely different type of need for the adversary. This pattern follows axiom 7 of the diamond model by looking at victims' capabilities to adversaries to define the relationship between them. Marriot first discovered the MimiKatz bug in 2018 and resolved that its control center was Chinese intelligence using a victim-centered approach to its problem. Few operators would be able to pull off such a task and maintain the cost. Another part of Marriots victimology is that Chinese intelligence is known for stealing but not crippling or damaging American companies but using the information to further state interest. And China is known for having high adversary persistence, which is in line with corollary 1 of the diamond model. The reason is that the relationship is one of opportunity and low costs.

The technology involved was the use of a spear-phishing email that contained a trojan virus. This allowed foreign actors to slowly escalate their privileges until they were administrative, which allowed them to use mimikatz to relay information saved back through HTTP communications over the different internet protocols back to foreign infrastructure. Because of Marriot international's immense scope, the ability for a spear-phishing attack to work

is not unreasonable. Still, it is usually detected through various scanners companies have installed to notice suspicious web activity because of how simple these types of attacks are. That a backdoor could persist so long to the point that 500 million accounts were comprised shows a lack of security on the part of the Marriot security team or at least that the systems of Marriot and Starwood had still not been adequately integrated even after years of being together. The sheer volume of information sent back to the Chinese infrastructure should have been detected much earlier and shows that the hackers' high level of capability to remain undetected. Axiom 5 of the diamond model would not be fulfilled if not for the Chinese government's vast resources to continue the attack at no immediate cost-benefit or profit.

Cyber espionage is defined by can be a countries " 'gathering or attempting to gather information in territory controlled by an adverse party (Buchan, 2018, pp. 883–885)). “ During times of peace, this type of information gathering can be quite challenging to prosecute. Every country has sovereignty in its boundaries, and other countries aren't required to hand over hackers or adversaries to victims of cyberattacks. It is in the best interest of a country to do otherwise. Thus policy on a transnational level would have no real teeth as there is no overarching governing body that can hold countries like the united states of America or China accountable for actions, especially since damages are usually not physical. This problem must be addressed primarily at the national level with supplemental guidance for organizations if they choose to follow suit. The welfare of a nation and its interests are not always in line with its businesses on an organizational level, and other countries have their interests at the transnational level. The first significant national policy change that could prevent the spying on government officials and military officials abroad would be these officials' ability to use a username or an alternative ID when dealing with American business overseas. When checking into these

companies, the companies could request verification from servers housed in secure government sites. Even if there is a breach with a proper protocol such as cycling of IDs and implementing timestamps on IDs, no breach will expose a large pattern for its users. The second national policy change would be how long companies can hold onto nonessential business operation information related to government and military officials. By limiting the scope a business can hold this information to one year, it would be possible to determine when a breach occurred based on who's information was stolen. An organization, Marriot international, could adopt similar practices for all its customers in an attempt to make them a less profitable target. The less data Marriot international maintains itself, the less likely it will be viewed as a potential target by bad actors. An organizational policy I would recommend for Marriot for future mergers is eliminating redundant systems and files to occur more efficiently. The backdoor was able to function for so long because Starwood's security was not directly under Marriot for some time but still under Starwood's original cyber team. Organizations have to have a unified infrastructure and systems to prevent cyber-attacks, not a mishmash of different technologies that communicate at the top or front ends but have entirely different backends.

In summary, cyber espionage is a transnational problem even in times of peace that is best confronted at the national level in which nations should at a national level create policies to ensure the safety of their information that they or their adversaries deem valuable. Marriot is a prime example of international espionage dangers because nation-state resources allow for persistence without target data leaking. Marriot's result was a "The company could face up to \$1 billion (Clark, 2018)" in fines and other legal expenses, but in comparison to its revenue, the real problem is the loss of faith of its customers. Most customers who are victims of any cyber attack do not go back to using compromised services. Not only did Chinese intelligence hackers steal

personal data, but they negatively affected American business revenue and future growth. On a national level, securing and encrypting high-level targets' data can mitigate damages. Still, because transnational policies are hard to enforce between countries, the best security policies will always be defensive regarding companies that must operate internationally.

References

Buchan, R. (2018). Cyber Espionage and International Law.

Hart Publishing.

Caltairone, S, Pendergast, A, & Betz, C (2013) The The Diamond Model of Intrusion Analysis

Center For Cyber Intelligence Analysis and Threat Research Hanover MD

Clark, P. (2018, December 14). Marriott Breach Exposes Weakness in Cyber Defenses for

Hotels. <https://www.bloomberg.com/news/articles/2018-12-14/marriott-cyber-breach-shows-industry-s-hospitality-to-hackers>

Cyber Daily: Look on the Bright Side. (2018). WSJ Pro.Cyber

Security, <https://go.openathens.net/redirector/gatech.edu?url=https://search.proquest.com/docview/2171174137?accountid=11107>

Fruhlinger, J. (2020, February 12). Marriott data breach FAQ: How did it happen and what was

the impact? CSO Online. <https://www.csoonline.com/article/3441220/marriott-data-breach-faq-how-did-it-happen-and-what-was-the-impact.html>

Hertzfeld, E. (2018, December 11). Report: Marriott hack could be Chinese intelligence. Hotel

Management. <https://www.hotelmanagement.net/tech/report-marriott-hack-could-be-chinese-intelligence>

Nation-State Cyber Espionage and its Impacts. (n.d.). [Www.Cse.Wustl.Edu](http://www.cse.wustl.edu).

[https://www.cse.wustl.edu/%7Ejain/cse57114/ftp/cyber_espionage/index.html#cyberspace and international law](https://www.cse.wustl.edu/%7Ejain/cse57114/ftp/cyber_espionage/index.html#cyberspace_and_international_law)

Petters, J. (2020, August 24). What is Mimikatz: The Beginner's Guide | Varonis. Inside Out

Security. <https://www.varonis.com/blog/what-is-mimikatz/>

Phishing Prevention – Best Practices for Protecting Your Small or Medium Size Business. (2020, March 19). PhishProtection.Com. <https://www.phishprotection.com/resources/phishing-prevention-best-practices/>

Phil's Stock World: Hack Of 500 Million Marriott Guests Traced To Chinese Intelligence Services (2018). . Newstex.

Staff, R. (2020, October 30). ICO fines Marriott 18.4 million pounds for failing to secure customer data. U.S. <https://www.reuters.com/article/us-marriott-intnl-ico/ico-fines-marriott-18-4-million-pounds-for-failing-to-secure-customer-data-idUSKBN27F1LH>

Telford, T. C. T. (2018, November 30). Marriott discloses massive data breach affecting up to 500 million guests. Washington Post. <https://www.washingtonpost.com/business/2018/11/30/marriott-discloses-massive-data-breach-impacting-million-guests/>